

INTERNAL SECURITY ASSESSMENT

ARTEX AI

Technical Vulnerability & Attack Surface Assessment

OVERALL RISK HIGH	CRITICAL PATH Fresh-install admin takeover	ASSESSMENT TYPE Source review + architecture threat model
----------------------	---	--

Report ID	ARTXP-SEC-2026-001	Version	1.0
Assessment date	2026-10-06	Classification	INTERNAL - RESTRICTED
Target	Autumn-27/ARTEX	Reviewed branch	main
Reviewed commit	b55ceb1fdd84a813d77de09a06af83d323a81f85	Latest release observed	v0.3.14 (2026-09-24)
Prepared for	Project ARTXploit	Status	Final research assessment

Use restriction

본 문서는 승인된 보안 연구 및 취약점 분석 목적으로 작성된 내부 문서입니다. 재현 전에는 대상 시스템의 소유권 및 테스트 권한을 확인해야 합니다.

Document Control & Assessment Basis

Assessment basis	GitHub source inspection + public security advisories	Code execution	No destructive testing against third-party deployments
Primary evidence	Source files, manifests, deployment configuration	Confidence scale	Confirmed / High confidence / Conditional / Design risk
Risk model	Likelihood x impact + privilege amplification	Scope limitation	Runtime-specific reachability may vary by deployment

Important interpretation notes

- “Confirmed”는 소스 코드에서 해당 경로 또는 보안 특성이 직접 확인되었다는 의미이며, 반드시 공급자에 의해 CVE 로 인정되었다는 의미는 아니다.
- ARTEX 는 공격 테스트를 수행하기 위해 원래부터 Bash, Python, HTTP, MCP, MITM 기능을 제공한다. 따라서 일부 항목은 기능 자체가 취약점이라기보다 인증/정책 경계가 깨졌을 때 영향이 급격히 확대되는 “privilege amplifier”로 평가한다.
- Next.js 관련 공개 CVE 는 package version 뿐 아니라 실제 production runtime 의 도달 가능성을 구분하였다. ARTEX 의 정식 embedded static export 는 Node server 전용 취약점의 기본 공격 경로를 상당 부분 제거한다.

Table of Contents

- 1. Executive Summary
- 2. System Architecture and Development Model
- 3. Dependency and Supply-Chain Review
- 4. Deployed Attack Surface
- 5. Detailed Findings
- 6. Exploit Chain Analysis
- 7. Prioritized Remediation Plan
- 8. Verification Checklist
- 9. Source Reliability and References
- Appendix A. Finding Register
- Appendix B. Assumptions and Limitations

1. Executive Summary

Executive conclusion

ARTEX는 일반 관리 웹앱이 아니라 “웹 관리 권한이 OS 명령 실행, 네트워크 접근, MITM 트래픽 수집 및 외부 Tool 호출 권한으로 연결되는” 고권한 보안 플랫폼이다. 따라서 인증·세션·MCP·Agent 정책 경계의 결함은 단순 정보 노출이 아니라 서버측 실행 권한 및 추가 credential compromise로 확대될 수 있다.

Overall Risk Rating: HIGH / Critical exposure exists when a new instance is reachable before administrator initialization.

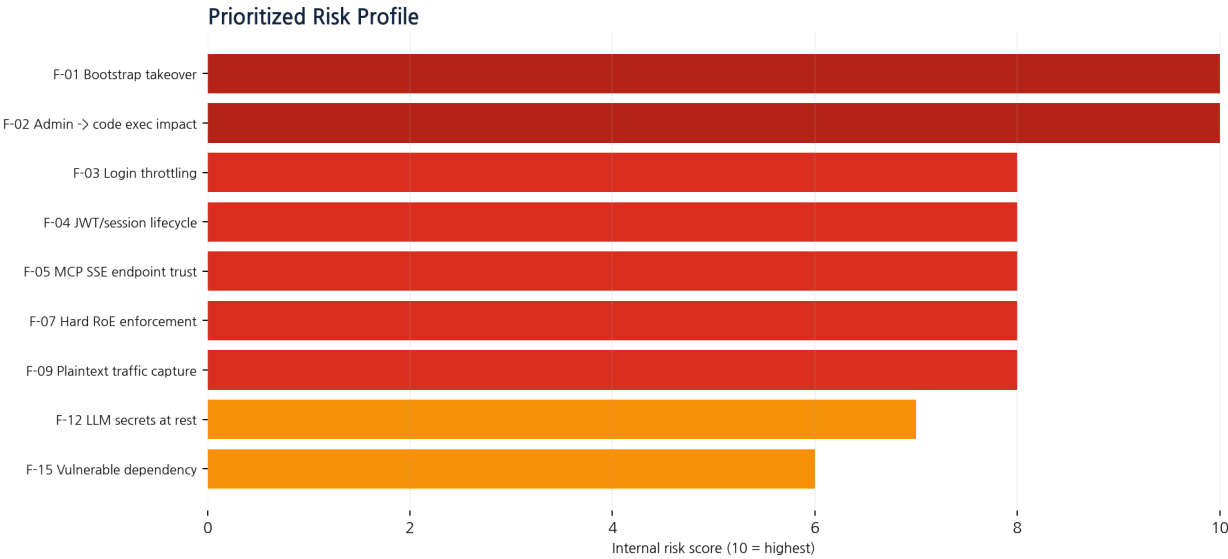


Figure 1. Internal prioritization of the most material findings.

ID	Severity	Confidence	Finding	Security effect
F-01	CRITICAL	Confirmed	Unauthenticated first-run administrator bootstrap	미초기화 인스턴스가 원격에서 접근 가능하면 최초 관리자 패스워드 설정 및 JWT 획득 가능
F-02	CRITICAL IMPACT	Architectural	Administrator session maps to server-side execution capability	Custom command/script tooling 때문에 admin session compromise가 Bash/Python 실행으로 확대
F-03	HIGH	Confirmed	Login throttling / lockout absent	온라인 password guessing 및 bcrypt CPU exhaustion 위험
F-04	HIGH	Confirmed	JWT/session lifecycle weaknesses	7 일 bearer token, localStorage/query token, password change 후 기존 token 무효화 부재
F-05	HIGH	High confidence	Legacy MCP SSE endpoint trust / SSRF	SSE 가 반환한 absolute message endpoint 를 same-origin 검증 없이 신뢰 가능
F-06	MED-HIGH	Conditional	MCP TLS verification can be disabled	insecure=true 시 MCP traffic 과 credential 의 MITM 가능성
F-07	HIGH	Confirmed design risk	Non-bypassable RoE	Hard scope

ID	Severity	Confidence	Finding	Security effect
			boundary absent	authorization 이 제거되어 configurable intercept + fallback 판단에 의존
F-08	HIGH IMPACT	Architectural	Custom HTTP tool is an SSRF-equivalent primitive	Agent/admin 가 ARTEX host 네트워크 위치에서 임의 HTTP request 수행 가능
F-09	HIGH	Confirmed	Full plaintext traffic capture	Authorization/ Cookie/body 등 민감 데이터가 평문 저장될 수 있음
F-10	MEDIUM	Confirmed	Traffic proxy fail-open affects evidence completeness	MITM 실패 host 가 passthrough 되어 요청은 진행되나 기록이 누락될 수 있음
F-11	MED-HIGH	Confirmed	Container executes as root by default	Container 내부 compromise impact 및 persistence 범위 확대
F-12	HIGH	Confirmed	LLM API secrets stored reversibly in PostgreSQL	DB compromise 시 provider credential 노출 가능
F-13	MEDIUM	Design risk	Self-update checksum shares publisher trust root	Release artifact 와 checksum 이 동일 publisher compromise 에 함께 영향
F-14	MEDIUM	Confirmed	Loose dependency/image pinning	@latest / latest 이미지가 reproducibility 와 supply-chain control 약화
F-15	MEDIUM	Confirmed dependency	klauspost/compress 1.18.6 affected by CVE-2026-63209	직접 S2 reachability 는 미확인이나 vulnerable dependency 존재

2. System Architecture and Development Model

ARTEX 는 Go 기반 monolithic control plane 에 정적 Next.js UI, PostgreSQL 상태 저장소, 로컬 SQLite traffic index, embedded MITM proxy, LLM Agent runtime, MCP 및 custom tool execution 을 결합한 형태다. 운영 관점에서는 하나의 서비스처럼 보이지만, 보안 관점에서는 다수의 고권한 trust boundary 가 한 프로세스와 동일한 관리자 세션 아래 연결되어 있다.

ARTEX AI - Trust Boundaries and Runtime Architecture

Security-sensitive boundaries are highlighted by privileged execution, external tool trust, traffic capture and update paths.

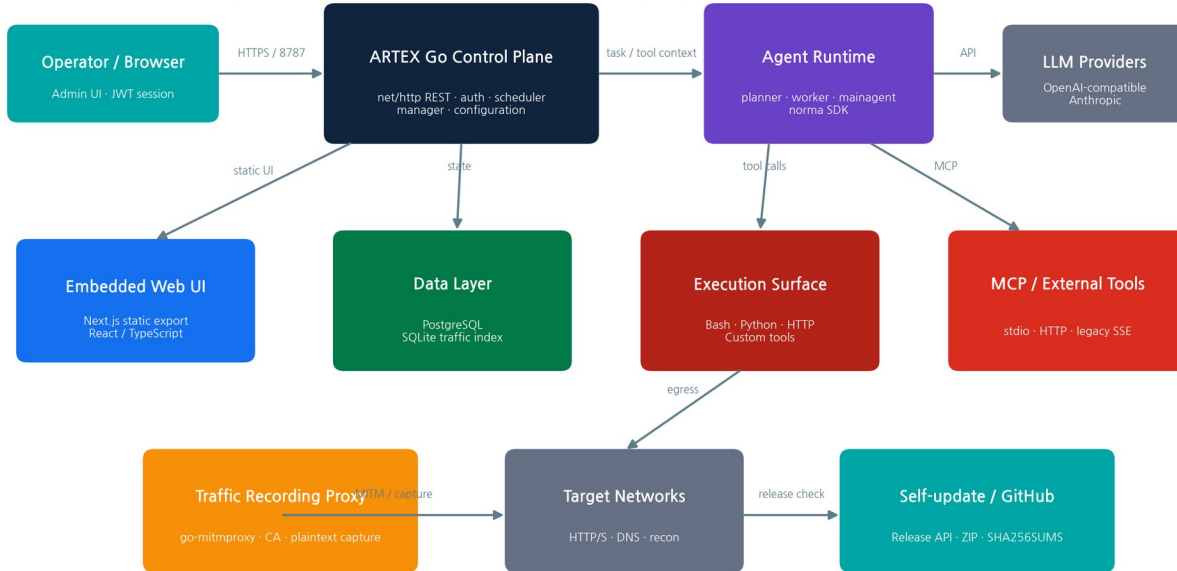


Figure 2. ARTEX trust boundaries and runtime components.

2.1 Backend and control plane

- Go `net/http` ServeMux 기반 REST API. `/api/\*`는 CORS + JWT middleware 를 통과하고, `/api/auth/\*`와 `/api/health`는 인증 예외다.
- Task manager/engine 가 planner 및 worker 의 lifecycle 을 관리하며 Agent runtime 은 `Autumn-27/norma` SDK 를 사용한다.
- 관리 API 에는 workspace, tools, MCP, LLM profile, intercept policy, traffic, findings, logs, update/rollback 등 높은 영향의 기능이 함께 존재한다.

2.2 Frontend delivery model

Frontend manifest 는 Next.js 16.2.9, React 19.2.7, TypeScript 5.9.3 등을 선언한다. 정적 embedded build 는 `NEXT\_EXPORT=1`을 사용해 순수 정적 산출물을 생성하고 Go binary 에 포함하는 구조다. 따라서 Next.js Node runtime 에 한정되는 공개 CVE 는 production embedded path 와 개발/별도 Node 배포를 분리해서 판단해야 한다.

2.3 Execution and data trust boundaries

Boundary	Privilege / data	Why it matters
Browser -> API	Global admin bearer session	한 세션이 거의 모든 관리 기능을 제어
Agent -> Tool	Bash/Python/HTTP/MCP	LLM 결정이 실제 side effect 로 이어짐
Traffic proxy	TLS plaintext / credentials	대상 시스템의 민감 정보가 수집될 수 있음
MCP / LLM	External service trust	Tool description/output 또는 provider 가 Agent 동작에 영향
Self-update	Executable replacement	Publisher compromise 시 코드 무결성

Boundary	Privilege / data	Why it matters
		경계
PostgreSQL	LLM keys + operational state	DB compromise 가 외부 provider 자격 증명으로 확장

3. Dependency and Supply-Chain Review

3.1 Go dependencies

Package	Version	Use	Assessment
github.com/Autumn-27/norma	v0.4.3	Core Agent SDK	High trust dependency
github.com/golang-jwt/jwt/v5	v5.3.1	JWT	Usage/lifecycle more material than version
github.com/jackc/pgx/v5	v5.10.0	PostgreSQL	No identified blocker in reviewed advisories
github.com/klauspost/compress	v1.18.6	Archive/compression	Affected by CVE-2026-63209; S2 path reachability not confirmed
github.com/lqyt2423/go-mitmproxy	v1.9.2	MITM proxy	Security-critical runtime dependency
modernc.org/sqlite	v1.52.0	Traffic index	Local storage component
golang.org/x/crypto	v0.55.0	bcrypt/crypto	Authentication primitive

CVE-2026-63209 / GHSA-259r-337f-4r4w

`github.com/klauspost/compress` <= 1.18.6 의 S2 `NewDict()` 처리에서 integer overflow 와 out-of-bounds access 가 보고되었고 1.18.7 에서 수정되었다. ARTEX 에서 확인된 직접 import 는 zstd 용도이므로 이 리포트는 “vulnerable dependency present”로 분류하되 remote reachability 를 확정하지 않는다.

3.2 Next.js advisory reachability

Advisory	Issue	Affected	ARTEX reachability assessment
GHSA-2xp9-vwfh-vxw4	AVIF Image Optimization unauth RCE	<16.3.3	ARTEX 16.2.9 manifest affected; embedded static export normally does not expose image optimizer runtime
GHSA-89xv-2m56-2m9x	Server Actions SSRF on custom servers	<16.2.11	Package affected; requires Server Actions/custom server runtime, not normal static export
GHSA-6gpp-xcg3-4w24	Turbopack App Router middleware/proxy bypass	<16.2.11	Primarily relevant to dev/Node deployments using affected path
GHSA-vcvr-r3jv-pc5j	next/og ImageResponse RCE	16.2.x affected range	No confirmed `next/og` use in reviewed ARTEX source; upgrade still recommended

Recommendation: static export 가 기본이라는 이유로 취약 버전을 장기 유지하지 말고, build/development 경로와 향후 deployment 변경 가능성까지 고려해 보안 수정 버전으로 업데이트한다.

4. Deployed Attack Surface

Type	Surface	Function	Trust actor	Risk	Notes
Inbound	TCP/8787	Go API + embedded UI	Remote user / internal user	CRITICAL	Default Docker compose publishes 8787:8787
Inbound	TCP/8788	Recording MITM proxy	Local/container clients	HIGH if exposed	Host-side default compose mapping is loopback-only
Internal	PostgreSQL 5432	Tasks/settings/ LLM keys	ARTEX backend	HIGH	Usually compose-internal; DB breach has high secondary impact
Filesystem	/app/data, workspace	JWT key, captures, transcripts, artifacts	ARTEX process/admin	HIGH	Sensitive operational material
Filesystem	/app/skills	Agent skills	ARTEX process/admin	HIGH	Writable skill supply chain can affect Agent behavior
Outbound	LLM providers	Prompt/context/ API keys	External provider	HIGH	Data confidentiality + model trust boundary
Outbound	MCP HTTP/SSE/stdio	Tool definitions and calls	Configured MCP	HIGH	Remote tool trust; legacy SSE endpoint issue
Outbound	Target networks	HTTP/DNS/recon	Assessment targets	HIGH	Core offensive capability
Outbound	GitHub Releases	Update metadata/artifacts	GitHub	MED-HIGH	Executable replacement path

4.1 Default deployment observations

- Backend default listen address is `:8787`; Docker Compose publishes host port 8787 to the container.
- Recording proxy is exposed by the image but the Compose example maps host side to `127.0.0.1:8788`, which materially reduces remote exposure when the example is followed.
- The production image does not declare a non-root USER, so the ARTEX process and child tools run as root inside the container by default.
- The admin/API surface should be treated as a remote execution control plane, not as a low-impact dashboard.

5. Detailed Findings

F-01 - Unauthenticated first-run administrator bootstrap

Severity	CRITICAL	Status	Confirmed by source
Components	server/auth.go; Docker/default bind configuration	Precondition	ARTEX backend reachable while `auth.password_hash` is not initialized.

Technical assessment

`/api/auth/\*` is excluded from the global JWT middleware. `POST /api/auth/init` accepts a password when no administrator hash exists, stores the bcrypt hash and returns an administrator JWT. No one-time installation secret, localhost-only enforcement or console nonce was observed in the reviewed path.

Attack scenario

A newly deployed or database-reset instance is reachable on TCP/8787 before the legitimate operator completes setup. A remote party initializes the administrator password first, obtains a valid global session, and can then access high-impact management APIs.

Impact

Initial control-plane takeover. Because authenticated administrators can define/test command or script tools, the impact can extend to server-side process execution, captured traffic access, LLM secrets and persistence inside the ARTEX runtime.

Recommended remediation

Require a one-time bootstrap secret generated on the server console; bind to loopback until setup is complete; optionally require an out-of-band installation token; emit a hard startup warning when externally bound and uninitialized.

Verification criteria

A new empty database must reject remote `/api/auth/init` requests that do not present the server-generated setup secret. The setup secret must be single-use and removed after initialization.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/server/auth.go>

F-02 - Administrator compromise directly amplifies to server-side code execution capability

Severity	CRITICAL IMPACT	Status	Architectural privilege amplifier
Components	server/customtool.go; management API routes	Precondition	Valid ARTEX administrator session or another path able to invoke/alter custom tooling.

Technical assessment

Custom tools support command, Python script and HTTP execution. Command tools invoke the Bash execution substrate; script tools write Python code to a temporary file and launch the configured interpreter. The custom-tool test endpoint exercises the same execution path before persistence.

Attack scenario

Any authentication/session vulnerability should be scored against the effective privilege of the admin plane: an attacker does not need a second memory-corruption primitive to achieve server-side execution if they can access the intended custom-tool capabilities.

Impact

Server-side command execution inside the ARTEX runtime; read/write access to mounted data and skills; access to environment variables and network positions; potential persistence in writable project/data directories.

Recommended remediation

Apply strong MFA or reverse-proxy identity controls for the admin plane; split “viewer/operator/tool-admin” roles; require explicit step-up authorization for command/script tool creation and test; isolate execution into a lower-privileged sandbox/container.

Verification criteria

A compromised low-privilege UI role must not be able to create/test command or script tools. Execution should occur under a separate unprivileged identity with constrained filesystem/network policy.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/server/customtool.go>

F-03 - No application-level login throttling or logout

Severity	High	Status	Confirmed by source
Components	server/auth.go	Precondition	Reachability of `/api/auth/login`.

Technical assessment

The login handler validates a fixed username (`ARTEX`) and bcrypt password but the reviewed code path does not enforce per-IP/account rate limiting, progressive delay, temporary logout or a global bcrypt concurrency cap.

Attack scenario

An attacker can repeatedly invoke the password verification path. This supports online guessing and can also force repeated CPU-expensive bcrypt operations.

Impact

Credential guessing risk and application-layer denial of service, especially when TCP/8787 is broadly reachable.

Recommended remediation

Add token-bucket limits per source and account; progressive backoff; bcrypt verification semaphore; observable failed-login metrics; upstream reverse-proxy limits as defense in depth.

Verification criteria

Automated login attempts must receive throttling before sustained bcrypt workload is reached; concurrent invalid login bursts should remain CPU-bounded.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/server/auth.go>

F-04 - JWT/session lifecycle is too permissive for a remote-execution control plane

Severity	High	Status	Confirmed by source
Components	server/auth.go; web/src/lib/auth.ts; web/src/lib/api.ts	Precondition	Token theft via client-side compromise, URL leakage, browser storage access, logs or other channel.

Technical assessment

Administrator JWTs are issued with a 7-day lifetime. Tokens can be accepted from Authorization, cookie or `?token=` query parameters. The frontend stores the token in localStorage and a JavaScript-created non-HttpOnly cookie. Password change/reset updates the password hash but does not revoke already-issued JWTs.

Attack scenario

A stolen token remains a bearer credential for the full lifetime even if the operator changes the password. Query-string tokens may additionally enter logging/observability surfaces; XSS impact is amplified by localStorage accessibility.

Impact

Long-lived administrator session hijack with the same high-impact management privileges described in F-02.

Recommended remediation

Use server-set `HttpOnly; Secure; SameSite=Strict/Lax` session cookies; eliminate query-token fallback where possible; shorten access-token lifetime; introduce session version or issued-before cutoff; revoke sessions on password change/reset; pin JWT algorithm to HS256 explicitly.

Verification criteria

Password change invalidates pre-change sessions immediately. No operational token should appear in browser localStorage or application URLs.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/server/auth.go>

F-05 - Legacy MCP SSE endpoint is trusted without same-origin restriction

Severity	HIGH	Status	High-confidence source finding
Components	mcphhttp/client.go; server/mcpdiscover.go	Precondition	An enabled legacy SSE MCP endpoint is malicious, compromised, or able to return attacker-controlled endpoint data.

Technical assessment

The legacy SSE flow accepts a `data:` endpoint from the server. Relative endpoints are resolved against the base URL, but an absolute URL is accepted without a same-origin restriction. Subsequent JSON-RPC POSTs are sent to that endpoint with configured MCP headers.

Attack scenario

A malicious MCP server can point the ARTEX client at an arbitrary absolute endpoint and cause server-originated POST traffic. In environments where the ARTEX host can reach internal services unavailable to the MCP server, this becomes a confused-deputy SSRF primitive.

Impact

Server-side request forgery, internal service interaction and possible credential/header propagation to an unintended origin.

Recommended remediation

Require scheme/host/port equality with the configured SSE origin by default. If cross-origin endpoints are required, use an explicit allowlist, strip credentials on origin change, and enforce private/link-local destination policy.

Verification criteria

A legacy SSE endpoint returning an absolute URL on a different origin must be rejected before any POST is attempted.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/mcphhttp/client.go>

F-06 - MCP TLS certificate verification can be disabled

Severity	MED-HIGH	Status	Conditional configuration risk
Components	mcphhttp/client.go	Precondition	Operator configures MCP `insecure=true`; attacker has network MITM position or DNS/control-plane influence.

Technical assessment

When `insecure` is enabled, the MCP client uses TLS with `InsecureSkipVerify`. This is understandable for self-signed development endpoints but removes endpoint authentication for a security-sensitive tool channel.

Attack scenario

A MITM can impersonate the MCP endpoint, observe bearer/custom headers, modify tool descriptions and return attacker-chosen tool output that influences Agent decisions.

Impact

Credential disclosure, integrity loss of tool results and potential Agent manipulation.

Recommended remediation

Default to verification; support custom CA bundles/certificate pinning instead of global verification bypass; surface a persistent high-risk warning when insecure mode is enabled.

Verification criteria

Self-signed deployments should succeed only when a trusted CA/pin is configured, not through blanket verification disablement.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/mcphttp/client.go>

F-07 - Hard Rule-of-Engagement scope enforcement is not a non-bypassable boundary

Severity	MEDIUM	Status	Confirmed design risk
Components	guard/guard.go; intercept rules	Precondition	Agent receives adversarial/ambiguous content or policy configuration does not match a tool call.

Technical assessment

The Guard source notes that the prior RoE authorization-scope mechanism was removed. Destructive/exfiltration gating is implemented through DB intercept rules, and unmatched calls may proceed when the fallback judge is disabled or unavailable. User-configured rules can be disabled/deleted.

Attack scenario

Target-controlled content enters Agent context, influences tool choice and reaches a policy layer that is configurable/fail-open rather than a mandatory destination invariant. This increases indirect prompt-injection/confused-deputy risk.

Impact

Potential out-of-scope network actions or execution of high-impact operations inconsistent with the intended engagement boundary.

Recommended remediation

Add a mandatory, non-disableable final policy enforcement point that checks resolved destination domain/IP/CIDR/port and tool class against the authorized engagement scope. Intercept prompts/rules should remain an additional review layer, not the ultimate scope boundary.

Verification criteria

No tool, including Bash/HTTP/MCP and custom tools, can reach a destination outside the approved scope even if every discretionary intercept rule is disabled.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/guard/guard.go>

F-08 - Custom HTTP tooling is an SSRF-equivalent privileged primitive

Severity	HIGH/IMPACT	Status	Architectural privilege amplifier
Components	server/customtool.go	Precondition	Admin/Agent can invoke an enabled custom HTTP tool.

Technical assessment

Custom HTTP tools render a configurable URL, headers and body and issue requests using a server-side HTTP client. Private/loopback destinations are not generally blocked because network reachability is a core pentest capability.

Attack scenario

Any Agent-control or admin-control weakness can reuse this intended capability to access services from the ARTEX host network position.

Impact

Internal network reachability, metadata/service access and data movement according to the server's routing privileges.

Recommended remediation

Treat custom HTTP as a high-impact capability; bind it to hard RoE enforcement, dedicated egress policy and per-tool destination constraints.

Verification criteria

Even an enabled custom HTTP tool cannot reach destinations excluded by the mandatory engagement scope.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/server/customtool.go>

F-09 - Traffic recorder stores complete captures in plaintext without redaction

Severity	High	Status	Confirmed by source
Components	traffic/traffic.go; traffic API	Precondition	Target traffic passes through recording proxy and contains credentials or other secrets.

Technical assessment

The traffic subsystem explicitly describes full plaintext capture without redaction. Request/response headers and bodies can therefore contain Authorization headers, cookies, session tokens, passwords and application data.

Attack scenario

A compromise of the ARTEX data volume, host/container filesystem or privileged admin session gives an attacker access to captured secrets originating from assessment targets.

Impact

Credential reuse against target environments, PII/application data exposure and cross-system blast-radius expansion.

Recommended remediation

Provide configurable secret redaction, selective body capture, retention TTL, encrypted storage, filesystem permission hardening and audit trails for sensitive capture access.

Verification criteria

Known Authorization/Cookie/password test values must be masked or encrypted at rest according to configured capture policy.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/traffic/traffic.go>

F-10 - Traffic proxy fail-open behavior weakens evidence completeness guarantees

Severity	Medium	Status	Confirmed by source
Components	traffic/traffic.go	Precondition	MITM interception fails for a target host/protocol condition.

Technical assessment

Hosts that cannot be intercepted are placed into a transparent passthrough path so the request can still reach the target even though it is no longer captured by the recorder.

Attack scenario

An operator may infer that absence of traffic evidence means no request occurred, while the proxy intentionally allows unrecorded passthrough traffic for selected hosts.

Impact

Audit/evidence blind spots and weaker non-repudiation of autonomous Agent actions.

Recommended remediation

Expose passthrough status prominently; record metadata for tunneled connections; support a strict mode that blocks when evidence capture is mandatory.

Verification criteria

Every passthrough event should produce an auditable record showing target, reason and time, even if payload capture is unavailable.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/traffic/traffic.go>

F-11 - Production container runs as root by default

Severity	MED-HIGH	Status	Confirmed by Dockerfile review
Components	Dockerfile	Precondition	Any server-side code execution or malicious tool execution inside the container.

Technical assessment

The production Dockerfile does not switch to a non-root USER. ARTEX and its child processes therefore execute as root inside the container unless the deployment overrides the identity.

Attack scenario

A compromised administrator/session or malicious tool gains root-level control over the container filesystem and mounted writable paths.

Impact

Greater persistence and secret-access capability within the container and its bind mounts. This is not equivalent to host root in the default compose because the Docker socket is not mounted.

Recommended remediation

Create a dedicated unprivileged user, drop capabilities, use read-only root filesystem where practical, isolate writable data/skills volumes and apply seccomp/AppArmor profiles.

Verification criteria

`id` inside the running ARTEX container should report an unprivileged UID; write tests should fail outside designated writable paths.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/Dockerfile>

F-12 - LLM provider API keys are stored reversibly in PostgreSQL

Severity	HIGH	Status	Confirmed by source
Components	db/config.go; db/schema.sql	Precondition	PostgreSQL compromise, database backup disclosure or privileged DB read.

Technical assessment

UI responses intentionally omit full API keys, but the database stores and reloads the provider key as a normal text value so the backend can call the configured LLM endpoint. No application-level key wrapping/KMS layer was observed.

Attack scenario

An attacker who gains read access to the ARTEX database can recover LLM/provider credentials and potentially use them outside ARTEX.

Impact

External provider account abuse, cost exposure and access to private AI gateways or compatible endpoints.

Recommended remediation

Use a secrets manager or envelope encryption with a deployment-specific key not stored in PostgreSQL; separate DB backup access from decryption authority.

Verification criteria

Database dumps should contain only ciphertext/token references; application startup should obtain decryption capability from a separate secret source.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/db/config.go>

F-13 - Self-update checksum does not protect against publisher compromise

Severity	MEDIUM	Status	Design risk
Components	selfupdate/github.go; selfupdate/stage.go	Precondition	Compromise of GitHub release publishing account/workflow or equivalent publisher authority.

Technical assessment

The updater has good transport controls: HTTPS, host allowlist, redirect checks, SHA256SUMS verification, re-hash and smoke test. However the ZIP and checksum are published under the same release trust root.

Attack scenario

A publisher compromise can replace the executable archive and publish a matching checksum, satisfying the updater's integrity check.

Impact

Trusted installation of attacker-controlled executable code across self-updating deployments.

Recommended remediation

Add an independent signing root: Sigstore/cosign verification, GitHub artifact attestations with policy, TUF, or an offline release-signing key.

Verification criteria

An artifact with a valid SHA256 but no valid independent signature/attestation must be rejected.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/selfupdate/stage.go>

F-14 - Loose package/image pinning reduces supply-chain reproducibility

Severity	MEDIUM	Status	Confirmed by build review
Components	Dockerfile; docker-compose.yml	Precondition	Rebuild/redeploy at a time when mutable upstream tags resolve to changed artifacts.

Technical assessment

The Dockerfile installs Playwright-related npm packages using `@latest`, and Compose defaults to an ARTEX image tag that can be `latest`. Mutable dependency resolution weakens reproducibility and provenance validation.

Attack scenario

A legitimate or compromised upstream change can enter future builds without an explicit repository version change.

Impact

Unexpected runtime changes or supply-chain compromise amplification in a security-sensitive execution environment.

Recommended remediation

Pin exact npm versions and container image digests; generate SBOM/provenance; update through controlled dependency PRs.

Verification criteria

Two builds from the same revision and lock inputs should resolve the same package and image digests.

Primary source: <https://github.com/Autumn-27/ARTEX/blob/main/Dockerfile>

F-15 - Known vulnerable `klauspost/compress` version is present

Severity	MEDIUM	Status	Confirmed dependency / reachability unconfirmed
Components	go.mod; archive/skill paths using zstd	Precondition	Affected S2 `NewDict()` path must be reachable with attacker-controlled dictionary input for the published DoS condition.

Technical assessment

ARTEX declares `github.com/klauspost/compress v1.18.6`. GHSA-259r-337f-4rfw / CVE-2026-63209 affects `compress/s2` through 1.18.6 and is fixed in 1.18.7. Reviewed ARTEX direct imports observed zstd usage, so exploit reachability was not confirmed.

Attack scenario

If a future or indirect path invokes the affected S2 dictionary code with attacker-controlled data, the published bug can cause out-of-bounds access and process crash.

Impact

Potential denial of service; dependency hygiene gap even where current path is not reachable.

Recommended remediation

Upgrade to >=1.18.7 and run `govulncheck`/reachability analysis in CI.

Verification criteria

Dependency graph must no longer resolve to 1.18.6 or an affected S2 package version.

Primary source: <https://github.com/klauspost/compress/security/advisories/GHSA-259r-337f-4rfw>

6. Exploit Chain Analysis

6.1 Critical chain: fresh deployment takeover

Critical Attack Path - Fresh Deployment Bootstrap Takeover

The path is conditional on a reachable deployment whose administrator password has not yet been initialized.

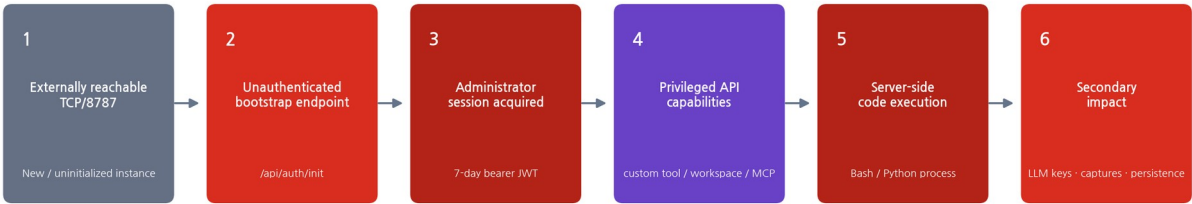


Figure 3. Conditional critical path for an externally reachable uninitialized instance.

Key condition

이 체인은 모든 ARTEX 설치에서 자동으로 성립하는 것이 아니다. “관리자 패스워드가 아직 초기화되지 않은 인스턴스가 공격자에게 네트워크로 reachable”해야 한다. 그러나 신규 배포/DB reset 과정에서 짧은 노출만 있어도 최초 설정 권한이 선점될 수 있다는 점 때문에 심각도를 Critical로 평가한다.

6.2 Agent chain: indirect prompt injection / confused deputy

Agent Trust-Boundary Risk - Indirect Prompt Injection / Confused Deputy

Risk increases when policy enforcement is configurable or fail-open rather than a non-bypassable destination/scope invariant.

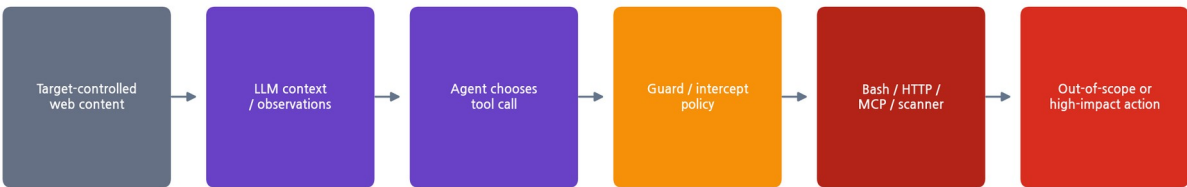


Figure 4. Agent tool-call trust path and the role of hard scope enforcement.

6.3 Compound-risk combinations

Entry condition	Finding combination	Resulting path
XSS or token leakage	F-04 + F-02	Browser-readable 7-day token -> admin privileges -> custom tool execution
Weak credential + no throttling	F-03 + F-02	Password guessing -> global admin plane -> execution capability
Compromised MCP	F-05/F-06 + Agent runtime	Endpoint redirection or MITM -> manipulated tool channel / internal

Entry condition	Finding combination	Resulting path
		POST
Target prompt injection	F-07 + F-08	Adversarial target content -> Agent tool choice -> server-position HTTP action
Filesystem/DB compromise	F-09 + F-12	Traffic secrets + LLM keys -> compromise extends beyond ARTEX itself

7. Prioritized Remediation Plan

Priority	Target window	Findings	Action
P0	Before any external deployment	F-01	Protect first-run initialization with one-time server-side setup secret; loopback-only until initialized.
P0	Immediate	F-03/F-04	Rate-limit login; remove query/localStorage token path; implement revocation/session version; shorten bearer lifetime.
P0	Immediate	F-07/F-08	Implement non-bypassable hard RoE/destination policy after DNS resolution and before every side effect.
P1	Immediate	F-05/F-06	Enforce same-origin legacy SSE endpoint and safe credential handling; replace insecure TLS with CA/pinning.
P1	30 days	F-02/F-11	Separate admin roles and execution privileges; sandbox tools; run ARTEX container as non-root.
P1	30 days	F-09/F-12	Redact/encrypt captures; move provider keys to secrets manager or envelope encryption.
P2	30-60 days	F-15 / Next advisories	Update affected dependencies and add `govulncheck` / npm audit/reachability CI.
P2	60 days	F-13/F-14	Add independent artifact attestation/signature and pin mutable packages/images to exact versions/digests.

7.1 Recommended target security architecture

- Identity plane: reverse-proxy SSO/MFA + short-lived HttpOnly session + role separation.
- Execution plane: separate unprivileged worker sandbox; no direct root-equivalent process execution from the web control plane.
- Policy plane: non-disableable scope compiler that resolves hostname -> IP/CIDR and evaluates every network/tool side effect.
- Secret plane: encrypted capture store + external secret manager for LLM/MCP/provider credentials.
- Supply-chain plane: exact dependency/digest pinning, SBOM, vulnerability reachability checks and independent release attestation.

8. Verification Checklist

Area	Acceptance criterion	Status
Bootstrap	Uninitialized remote instance cannot be claimed without a console-generated one-time token.	[] Pending
Authentication	Login bursts are throttled before creating unbounded bcrypt workload.	[] Pending
Session	Password change/reset immediately invalidates every prior session.	[] Pending
Browser	No admin bearer credential exists in localStorage or URL query parameters.	[] Pending
RoE	Disabled intercept rules cannot permit an out-of-scope destination.	[] Pending
MCP	Legacy SSE cross-origin message endpoint is rejected; credentials never follow cross-origin redirects/endpoints.	[] Pending
Container	ARTEX and tool processes run as a non-root UID with constrained mounts/capabilities.	[] Pending
Traffic	Configured Authorization/Cookie/password fields are redacted/encrypted at rest.	[] Pending
Secrets	PostgreSQL backup alone does not reveal usable LLM/MCP provider secrets.	[] Pending
Dependencies	`klauspost/compress` resolves to $\geq 1.18.7$; Next.js security-fixed line is used in dev/runtime builds.	[] Pending
Update	Unsigned/unattested release artifact is rejected even if its SHA256 matches a release-provided checksum.	[] Pending
Audit	Transparent proxy passthrough events remain visible in audit/evidence records.	[] Pending

9. Source Reliability and References

신뢰도는 “해당 자료가 ARTEX 의 현재 코드/취약점 사실을 입증하는 데 얼마나 직접적인가”를 기준으로 분류했다. 1 차 source 를 우선 사용하고, 2 차 자료는 architecture 보조 확인 용도로만 취급한다.

Trust	Source	URL	Use
A - Primary / authoritative	ARTEX upstream repository	https://github.com/Autumn-27/ARTEX	현재 소스, build, deployment, change history 의 직접 근거
A - Primary / authoritative	ARTEX auth implementation	https://github.com/Autumn-27/ARTEX/blob/main/server/auth.go	Bootstrap/JWT/login 판단의 직접 근거
A - Primary / authoritative	ARTEX custom tool implementation	https://github.com/Autumn-27/ARTEX/blob/main/server/customtool.go	Server-side execution/HTTP tool 판단
A - Primary / authoritative	ARTEX Guard implementation	https://github.com/Autumn-27/ARTEX/blob/main/guard/guard.go	RoE/intercept fail-open 설계 판단
A - Primary / authoritative	ARTEX MCP HTTP/SSE client	https://github.com/Autumn-27/ARTEX/blob/main/mcphttp/client.go	Legacy SSE endpoint/TLS 판단
A - Primary / authoritative	ARTEX traffic subsystem	https://github.com/Autumn-27/ARTEX/blob/main/traffic/traffic.go	Plaintext capture/fail-open proxy 판단
A - Primary / authoritative	ARTEX Go dependencies	https://github.com/Autumn-27/ARTEX/blob/main/go.mod	Dependency versions
A - Vendor advisory	klauspost/compress GHSA-259r-337f-4rfw	https://github.com/klauspost/compress/security/advisories/GHSA-259r-337f-4rfw	CVE-2026-63209 affected/patched range
A - Vendor advisory	Next.js security advisories	https://github.com/vercel/next.js/security/advisories	Next.js 2026 advisory corpus
A/B - GitHub Reviewed Advisory	Next.js AVIF RCE	https://github.com/vercel/next.js/security/advisories/GHSA-2xp9-vwf4-vxw4	Affected <16.3.3; runtime reachability assessed separately
A - Vendor advisory	Next.js Server Actions SSRF	https://github.com/vercel/next.js/security/advisories/GHSA-89xv-2m56-2m9x	Affected 16.0.0-16.2.10 custom-server path
C - Secondary	Zendot ARTEX overview	https://zendot.org/en/posts/autumn-27-artex	Architecture orientation only; not used as proof of a vulnerability
C - Secondary	MrKeyoor ARTEX review	https://mrkeyoor.com/repos/artex/	Independent review; non-authoritative
D - Automated/secondary	GitDiagram ARTEX	https://gitdiagram.com/autumn-27/artex	Visualization aid only

Appendix A. Finding Register

ID	Severity	Type	Exploit precondition	Impact class	Owner/status
F-01	CRITICAL	Source-confirmed	ARTEX backend reachable while `auth.password_hash` is not initialized.	RCE / control plane	Open - remediation recommended
F-02	CRITICAL IMPACT	Design / Architecture	Valid ARTEX administrator session or another path able to invoke/alter custom tooling.	RCE / control plane	Open - remediation recommended
F-03	HIGH	Source-confirmed	Reachability of `/api/auth/login`.	Hardening / supply chain	Open - remediation recommended
F-04	HIGH	Source-confirmed	Token theft via client-side compromise, URL leakage, browser storage access, logs or other channel.	RCE / control plane	Open - remediation recommended
F-05	HIGH	Source-confirmed	An enabled legacy SSE MCP endpoint is malicious, compromised, or able to return attacker-controlled endpoint data.	Network / scope	Open - remediation recommended
F-06	MED-HIGH	Conditional	Operator configures MCP `insecure=true`; attacker has network MITM position or DNS/control-plane influence.	Network / scope	Open - remediation recommended
F-07	HIGH	Source-confirmed	Agent receives adversarial/ambiguous content or policy configuration does not match a tool call.	Network / scope	Open - remediation recommended
F-08	HIGH IMPACT	Design / Architecture	Admin/Agent can invoke an enabled custom HTTP tool.	Network / scope	Open - remediation recommended
F-09	HIGH	Source-confirmed	Target traffic passes through recording proxy and contains credentials or other secrets.	Confidentiality	Open - remediation recommended

ID	Severity	Type	Exploit precondition	Impact class	Owner/status
F-10	MEDIUM	Source-confirmed	MITM interception fails for a target host/protocol condition.	Hardening / supply chain	Open - remediation recommended
F-11	MED-HIGH	Source-confirmed	Any server-side code execution or malicious tool execution inside the container.	Hardening / supply chain	Open - remediation recommended
F-12	HIGH	Source-confirmed	PostgreSQL compromise, database backup disclosure or privileged DB read.	Confidentiality	Open - remediation recommended
F-13	MEDIUM	Design / Architecture	Compromise of GitHub release publishing account/workflow or equivalent publisher authority.	Hardening / supply chain	Open - remediation recommended
F-14	MEDIUM	Source-confirmed	Rebuild/redeploy at a time when mutable upstream tags resolve to changed artifacts.	Hardening / supply chain	Open - remediation recommended
F-15	MEDIUM	Source-confirmed	Affected S2 `NewDict()` path must be reachable with attacker-controlled dictionary input for the published DoS condition.	Hardening / supply chain	Open - remediation recommended

Appendix B. Assumptions and Limitations

- 본 평가는 공개 GitHub source와 공개 advisory를 중심으로 수행한 source-based security assessment이며, 제 3자 production instance에 대한 침투 테스트는 포함하지 않는다.
- 환경별 reverse proxy, SSO, firewall, Kubernetes NetworkPolicy, secrets manager, custom Docker overrides가 존재하면 실제 attack surface와 impact가 달라질 수 있다.
- Dependency advisory는 package-level 영향 범위와 ARTEX의 실제 runtime reachability를 분리해서 기록하였다. “Affected version”만으로 원격 exploitability를 단정하지 않는다.
- Critical bootstrap finding은 uninitialized 상태라는 전제조건이 있다. 이미 안전하게 초기화된 인스턴스에서는 동일 경로가 403으로 거부되도록 구현되어 있다.
- Agent/prompt-injection 관련 항목은 LLM의 비결정성과 운영 정책에 영향을 받으므로, production-like sandbox에서 adversarial test corpus를 사용한 동적 재검증이 추가로 권장된다.

Final assessment

ARTEX의 가장 중요한 보안 특성은 “관리 권한과 실제 공격 도구 실행 권한이 매우 가까이 연결되어 있다”는 점이다. 따라서 첫-run bootstrap, session protection, hard RoE, MCP trust, secret/capture storage를 일반 웹 관리 시스템보다 한 단계 높은 보안 경계로 설계해야 한다.